CYBERFOX SOCIETY

Cybersecurity Research & Development Internship

Week 1 – Problem Identification & Research

Project Area: Web & API Security
Project Title: APIShield – Automated API Security Analyzer
Week: 1

---

1. Problem Identification

Modern web applications increasingly rely on APIs to exchange data between frontend applications, mobile applications, microservices, and third-party systems. APIs often expose sensitive application functionality and data, making insecure authentication, broken access controls, excessive information exposure, and insecure HTTP configurations significant security concerns.

The specific problem identified for this project is:

> **Developers and security learners need a lightweight and automated way to identify common API security weaknesses, especially authentication issues, broken access controls such as BOLA, sensitive information exposure, and insecure HTTP/security configurations, while performing security testing safely in an authorized environment.**

Existing API testing approaches can require manual configuration, security expertise, or multiple tools to test different categories of API weaknesses. This can make it difficult for beginners and small development teams to obtain a consolidated security assessment of an API.

Therefore, this project proposes **APIShield**, a defensive API security analyzer that performs automated security checks against an authorized API and produces understandable security findings and risk information.

---

2. Project Objectives

The main objectives of APIShield are:

1. Identify common security weaknesses in APIs through automated security checks.

2. Analyze authentication and authorization behavior.
3. Detect potential Broken Object Level Authorization (BOLA) issues.
4. Identify sensitive information exposure in API responses.
5. Analyze HTTP security headers and CORS-related configurations.
6. Provide severity-based security findings with explanations.
7. Generate an overall risk assessment using a clearly labeled heuristic score.
8. Protect credentials and sensitive information during scanning and reporting.
9. Perform scanning only against authorized targets.
10. Provide results in a form that is understandable to developers and cybersecurity learners.

---

3. Existing Solutions Research

3.1 OWASP ZAP

OWASP ZAP is an established web application security testing tool. OWASP also maintains an API Security Tools resource that includes ZAP and other API security solutions.

ZAP provides automated security testing capabilities and can be used for identifying web application security weaknesses.

Limitation/opportunity identified:
A general-purpose security testing platform can be powerful but may be more complex for beginners who specifically want a focused API security assessment covering authentication, authorization, information exposure, and HTTP configuration in a simple workflow.

3.2 Burp Suite

Burp Suite is a widely used web security testing platform. It provides functionality for intercepting and analyzing HTTP traffic and can be used for security testing of APIs and web applications.

Limitation/opportunity identified:
Burp Suite provides extensive capabilities, but effective API security testing often requires the tester to understand the tool and manually construct or configure different tests. A focused analyzer could provide a more guided workflow for common API security checks.

3.3 Postman

Postman is widely used for API development and testing. It supports API requests, collections, scripts, assertions, and different authentication mechanisms. Postman

documentation also describes testing approaches such as integration, end-to-end, regression, and performance testing.

Limitation/opportunity identified:
Postman is primarily an API development and testing platform rather than a dedicated automated security vulnerability analyzer. Security checks can be implemented using scripts and collections, but this may require the user to design the security tests themselves.

---

4. Research Findings

The research indicates that existing tools provide valuable API testing and security capabilities, but there is an opportunity for a focused solution that combines several common security checks into a single simplified workflow.

The main opportunity identified is to build a tool that:

- focuses specifically on API security;
- automatically performs a predefined set of security checks;
- analyzes authentication and authorization behavior;
- checks for potential BOLA/access-control issues;
- identifies sensitive information exposure;
- analyzes HTTP security headers and CORS;
- provides severity and reasoning for each finding;
- masks sensitive evidence;
- produces a consolidated security assessment;
- is suitable for controlled and authorized environments.

---

5. Proposed Solution – APIShield

APIShield is proposed as an automated API security analyzer for authorized testing environments.

The analyzer will accept an API target and perform a controlled set of security checks. The scanner will use a guarded HTTP client with protections against unsafe target access and will analyze the API responses and behavior.

The major planned detection categories are:

Authentication

- Missing or weak authentication controls
- Invalid credential handling
- Authentication-related security issues

Authorization

- Broken Object Level Authorization (BOLA)
- Inconsistent access-control behavior
- Unauthorized resource access

Information Exposure

- API keys or secret-like values
- Sensitive data exposure
- Debug information
- Stack traces and database error information

HTTP Security

- Missing security headers
- Insecure CORS configurations
- Insecure HTTP behavior
- Other suspicious response configurations

The findings will be assigned severity levels and accompanied by explanations and evidence. A heuristic risk score will also be generated to summarize the overall assessment.

---

6. Safety and Ethical Scope

APIShield will be designed as a defensive security tool.

Testing will be performed only against APIs for which the tester has authorization. For development and validation, the project uses an intentionally vulnerable local API containing fake data.

The scanner will also include protections against unsafe target access, including SSRF-related protections, request limits, response-size limits, credential isolation, and sensitive-data masking.

This approach follows the internship requirement that projects must use ethical cybersecurity practices and authorized environments.

---

7. Expected Outcome

The expected outcome is a functional MVP capable of:

1. Accepting an authorized API target.
2. Performing automated security checks.

3. Detecting common API security weaknesses.
4. Producing understandable findings.
5. Assigning severity levels.
6. Providing an overall heuristic risk assessment.
7. Protecting sensitive credentials and evidence.
8. Providing persistent scan results and reports in later development phases.

---

8. Conclusion

API security is an important area because APIs expose application functionality and potentially sensitive data. The research of existing API development and security testing solutions shows that powerful tools already exist, but there is an opportunity to create a focused, beginner-friendly and automated API security analyzer.

APIShield will address this opportunity by combining common API security checks, controlled scanning, risk classification, secure evidence handling, and consolidated results into a single defensive MVP.

The project will be developed and tested incrementally in an authorized environment throughout the internship.

References

1. OWASP API Security Project – API Security concepts and risks.
2. OWASP API Security Tools – API security testing tools.
3. PortSwigger Burp Suite Documentation – REST API and security testing capabilities.
4. Postman Documentation – API testing, authentication, authorization, and security practices.